
POL-002

D&D SERVICIO INTEGRAL DE LIMPIEZA

Política de Gestión de Contraseñas

Preparado para

D&D Servicio Integral de Limpieza

Código

POL-002

Clasificación

Interno

Elaborado Por

Francisco Noya

Versión

1.0

Fecha

30 de Julio de 2026

1. Objetivo

Establecer los requisitos y controles minimos que deben cumoplrser en la creacion, uso, almacenamiento, protección y gestión del ciclo de vida de las contraseñas y demás credenciales de autenticación utilizadas en los sistemas de información de D&D Servicio Integral de Limpieza, con el fin de reducir el riesgo de accesos no autorizados, suplantación de identidad y compromiso de la información.

2. Alcance

Esta política aplica a:

- Todos los empleados, contratistas, proveedores, consultores y terceros que accedan a los sistemas de información, redes, aplicaciones o servicios en la nube de DYD Servicio Integral de Limpieza.
- Todas las cuentas de usuario, cuentas privilegiadas o administrativas, cuentas de servicio, cuentas de sistema y cuentas de aplicación.
- Todos los sistemas, plataformas, dispositivos y servicios que requieran autenticación mediante contraseña u otro factor de autenticación, sean estos on-premise, en la nube o híbridos.

Quedan fuera del alcance las contraseñas de uso estrictamente personal que no tengan relación con los activos de informacion de la empresa

3. Objetivos de Seguridad

DYD Servicio Integral de Limpieza establece como objetivos en materia de gestión de contraseñas:

- Reducir el riesgo de accesos no autorizados a los sistemas de la información
- Garantizar que las credenciales de autenticación sean robustas y estén debidamente protegidas.
- Promover el uso de autenticación multifactor como control complementario a la contraseña.
- Cumplir con la legislación y normativa aplicable en materia de protección de datos.
- Mejorar continuamente las prácticas de gestión de credenciales.

4. Principios de Seguridad

Todas las decisiones relacionadas con la gestión de contraseñas deberán respetar los siguientes principios:

4.1 Confidencialidad

Las contraseñas son personales, confidenciales e intransferibles; no deben compartirse bajo ninguna circunstancia.

4.2 Robustez

Toda contraseña deberá cumplir con los requisitos mínimos de longitud y complejidad definidos en esta política.

4.3 Responsabilidad Individual

Cada usuario es responsable de proteger sus propias credenciales y de reportar cualquier sospecha de compromiso.

4.4 Verificación Adicional

Siempre que sea técnicamente viable, deberá utilizarse autenticación multifactor (MFA) como control complementario a la contraseña.

4.5 Gestión del Riesgo

El nivel de exigencia de los controles de contraseñas deberá ser proporcional al riesgo del sistema o la información que protegen.

5. Roles y Responsabilidades

Dirección

La Dirección deberá:

- Aprobar esta política
- Proporcionar los recursos necesarios para su implementación.
- Apoyar las iniciativas de seguridad relacionadas con la gestión de credenciales.

Responsable de Ciberseguridad

Será responsable de:

- Mantener esta política actualizada.
- Definir y supervisar los controles técnicos de contraseñas (complejidad, expiración, bloqueo de cuentas, MFA).
- Aprobar las herramientas de gestión de contraseñas utilizadas por la organización.
- Coordinar la respuesta ante incidentes relacionados con el compromiso de credenciales.

Usuarios

Todo usuario deberá:

- Cumplir esta política.
- Crear y proteger sus contraseñas conforme a los lineamientos establecidos.
- Reportar de inmediato cualquier sospecha de compromiso de sus credenciales.
- No compartir sus contraseñas con otras personas, incluyendo personal de TI.

6. Lineamientos Generales

Todos los usuarios y sistemas deberán cumplir las siguientes normas:

Longitud y complejidad

Las contraseñas de cuentas estándar deberán tener una longitud mínima de 12 caracteres, y las de cuentas privilegiadas o administrativas de 16 caracteres, combinando mayúsculas, minúsculas, números y caracteres especiales. No deberán utilizarse datos fácilmente deducibles (nombre de usuario, fechas de nacimiento, secuencias comunes).

Vigencia y renovación

Las contraseñas de cuentas estándar deberán renovarse cada 180 días y las de cuentas privilegiadas cada 90 días. No está permitido reutilizar ninguna de las últimas 10 contraseñas utilizadas en la misma cuenta.

Almacenamiento y transmisión

Las contraseñas nunca deberán almacenarse ni transmitirse en texto plano. Los sistemas deberán almacenar las contraseñas mediante funciones de hash criptográficas robustas. El uso de gestores de contraseñas corporativos aprobados es obligatorio para el almacenamiento de credenciales compartidas o de sistemas.

Autenticación multifactor (MFA)

Es obligatorio el uso de MFA para el acceso remoto, correo corporativo, servicios en la nube y cuentas con privilegios administrativos, conforme a la Política de Control de Accesos.

Bloqueo de cuentas

Las cuentas se bloquearán automáticamente después de 5 intentos fallidos consecutivos de autenticación. El desbloqueo requerirá la intervención del área de TI.

Cuentas de servicio y administrativas

Las cuentas de servicio deberán utilizar contraseñas de alta complejidad, generadas y almacenadas mediante un gestor de secretos aprobado, y deberán cambiar su contraseña por defecto antes de ser puestas en producción.

Reporte de incidentes

Todo incidente o sospecha de compromiso de una contraseña deberá comunicarse inmediatamente al Responsable de Ciberseguridad.

7. Cumplimiento

El incumplimiento de esta política podrá derivar en:

- Suspensión de accesos.
- Medidas disciplinarias internas.
- Acciones legales cuando corresponda.
- Revisión de permisos y responsabilidades.

8. Excepciones

Toda excepción a esta política deberá:

- Estar documentada.
- Contar con una justificación de negocio.
- Ser aprobada por la Dirección.
- Ser evaluada desde el punto de vista del riesgo.

9. Revisión de la Política

Esta política deberá revisarse:

- Como mínimo una vez al año.
- Cuando existan cambios importantes en la organización.
- Luego de incidentes relevantes de seguridad.
- Cuando cambie la legislación aplicable.

10. Documentos Relacionados

- POL-001 – Política de Seguridad de la Información
- POL-003 – Política de Control de Accesos
- POL-004 – Política de Uso Aceptable de Recursos Informáticos
- POL-005 – Política de Copias de Seguridad
- POL-006 – Política de Gestión de Incidentes
- Manual de Gestión de Riesgos

11. Referencias

- ISO/IEC 27001:2022 – Sistemas de Gestión de Seguridad de la Información.
- ISO/IEC 27002:2022 – Controles de Seguridad de la Información (control 5.17 y controles relacionados de acceso).
- NIST Cybersecurity Framework (CSF) 2.0 – Función PROTECT (PR), categoría PR.AA.
- NIST Special Publication 800-63B – Digital Identity Guidelines.

12. Control de Versiones

Versión	Fecha	Descripción	Autor
1.0	___ / ___ / 2026	Emisión inicial	Francisco Noya

13. Aprobación

Cargo	Nombre	Firma	Fecha
Director / Gerente General			
Responsable de Ciberseguridad	Francisco Noya		